

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 23

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM6-058)

Scenario: A municipal library system is expanding from physical lending to digital media, remote membership, and community learning portals. Its security program focuses on branch workstations.

Which basis should guide the revised program objectives?

- A. The age of existing security tools
- B. The practices of the largest commercial streaming service
- C. The digital services, user information, public obligations, dependencies, and associated risks
- D. The initiatives that require no change to library processes

Question 2 (CISM6-059)

Scenario: A consumer-products group acquired several brands that retain independent technology teams. Brand leaders treat central security requirements as optional because decision rights are undefined.

Which program foundation should the information security manager establish FIRST?

- A. A technical configuration catalog for every brand
- B. A separate unrelated security policy for each brand
- C. An audit schedule managed by the security operations team
- D. An approved charter defining enterprise authority, brand responsibilities, scope, objectives, sponsorship, and escalation

Question 3 (CISM6-060)

Scenario: A biotechnology company will share research platforms with a new partner in five months. Its roadmap schedules data-classification integration and partner monitoring for the next fiscal year.

Which roadmap response is MOST appropriate?

- A. Reassess the partnership risks and dependencies, then propose a funded sequence aligned with the launch date.
- B. Add every partnership task without changing resources or priorities.
- C. Keep the current sequence because approved roadmaps should not change.
- D. Begin information sharing and address program gaps after the partnership matures.

Question 4 (CISM6-061)

Scenario: A delivery platform connects customers, independent couriers, merchants, payment providers, and mapping services. It owns the customer experience but not every technology component.

Which scoping decision is MOST appropriate?

- A. Include only technology directly owned by the platform.
- B. Map end-to-end services, information flows, obligations, risks, dependencies, and accountable interfaces across participants.
- C. Transfer all customer and courier risk to service providers.
- D. Exclude independent couriers because they are not employees.

Question 5 (CISM6-062)

Which information provides the BEST basis for staffing a security and privacy design-review capability?

- A. Forecast review demand, risk tiers, service levels, required competencies, workflow complexity, and automation
- B. The current size of the legal department
- C. The number of security products currently licensed
- D. The average review-team size reported by one peer

Question 6 (CISM6-063)

Scenario: A regional utility needs short-term architecture expertise for a major modernization. Internal staff know operational requirements but lack experience with comparable transformations.

Which resourcing model is MOST appropriate?

- A. Transfer permanent architecture ownership to a technology supplier.
- B. Let advisors accept operational risk for the utility.
- C. Use qualified advisors under internal governance, with defined deliverables, knowledge transfer, and retained decision ownership.
- D. Postpone modernization until all expertise can be recruited internally.

Question 7 (CISM6-064)

Scenario: A hotel operator is considering a platform to automate supplier-risk workflows. Current supplier records are incomplete, and procurement processes differ across regions.

Which analysis should drive the investment decision?

- A. A business case covering risk reduction, benefits, dependencies, effort, and cost
- B. A ranking based on vendor market visibility
- C. A promise that automation will eliminate supplier risk
- D. A feature-count comparison between products

Question 8 (CISM6-065)

Scenario: A healthcare technology company depends on one senior manager for supplier oversight and program reporting. Retirement is expected within a year, and no successor has been prepared.

Which action should the information security manager take FIRST?

- A. Stop documenting the role until a replacement is selected.
- B. Create a competency and succession plan covering knowledge transfer, development, recruitment, and interim support.
- C. Wait for retirement before requesting resources.
- D. Assign the vacant capabilities to internal audit.

Question 9 (CISM6-066)

Which role normally approves the classification of a business information asset?

- A. The accountable information owner
- B. The system operator
- C. The storage provider
- D. The independent auditor

Question 10 (CISM6-067)

Which practice BEST prevents information assets from becoming ownerless after reorganizations?

- A. Updating ownership only during external audits
- B. Assigning all assets permanently to the security team
- C. Embedding ownership review and reassignment into organizational change and asset lifecycle processes
- D. Keeping former employees listed until systems are replaced

Question 11 (CISM6-068)

Scenario: A film-production company labels footage as confidential, but crews use portable media without consistent rules for encryption, custody, transport, reuse, or disposal.

Which program improvement is MOST appropriate?

- A. Remove confidentiality labels from portable copies.
- B. Require security to approve every media movement manually.
- C. Measure only the number of media devices purchased.
- D. Define classification-based media controls and embed them in production and partner workflows.

Question 12 (CISM6-069)

Scenario: A manufacturer sells a product division. Shared systems contain records needed by both companies, and no one has determined which copies may be transferred, retained, or deleted.

Which lifecycle recommendation should the information security manager make FIRST?

- A. Let system administrators decide which records belong to each company.
- B. Assign accountable owners and determine business, contractual, and legal requirements before controlled transfer, retention, and disposal.
- C. Delete all records associated with the division immediately.
- D. Copy every shared record to the buyer indefinitely.

Question 13 (CISM6-070)

What should be the PRIMARY consideration when selecting a security framework?

- A. The number of controls described in the framework
- B. The framework publisher's market visibility
- C. Its fit with organizational objectives, risks, obligations, capabilities, and governance
- D. Its ability to eliminate the need for management judgment

Question 14 (CISM6-071)

Why should a framework be tailored before detailed implementation planning?

- A. To remove practices that require cooperation from business units
- B. To focus effort on relevant outcomes while preserving traceability to risks and applicable requirements
- C. To guarantee that all residual risk will be eliminated
- D. To make future governance unnecessary

Question 15 (CISM6-072)

Scenario: An online marketplace maintains separate control libraries for three regions. Similar requirements use different terms, causing duplicate implementation and testing.

Which integration approach is MOST appropriate?

- A. Adopt the least demanding regional library for all markets.
- B. Map regional requirements to a common control and evidence model while preserving unique obligations and traceability.
- C. Maintain completely separate controls for every requirement statement.
- D. Ignore terminology differences without performing a mapping.

Question 16 (CISM6-073)

Which document normally states management's high-level mandatory direction for information security?

- A. Test record
- B. Procedure
- C. Guideline
- D. Policy

Question 17 (CISM6-074)

When is an information security guideline MOST appropriate?

- A. When program authority must be established
- B. When a mandatory technical minimum must be enforced
- C. When recommended approaches can help users meet requirements in varying circumstances
- D. When residual risk must be formally accepted

Question 18 (CISM6-075)

Scenario: A factory quality system cannot meet a new authentication standard until a certified upgrade is available. The owner requests an eight-month exception with additional monitoring.

Which conditions should the information security manager require?

- A. Documented risk, accountable approval, compensating controls, monitoring, review triggers, and a defined expiration date
- B. Permanent removal of certified systems from the standard
- C. Approval only from the technician who supports the system
- D. Evidence that the system has never been attacked

Question 19 (CISM6-076)

Scenario: A company centralizes supplier onboarding, but approved procedures still assign security checks to local procurement roles that no longer exist. The governing policy and standard remain valid.

Which document-governance response is MOST appropriate?

- A. Rewrite the policy solely because operating steps changed.
- B. Update, approve, and communicate the affected procedures while retaining traceability to the valid policy and standard.
- C. Allow each office to create an informal replacement process.
- D. Ignore the procedures because onboarding has been centralized.

Question 20 (CISM6-077)

Scenario: A professional association is consolidating independent member portals into shared services. Existing portals use incompatible identity, logging, and data-protection approaches.

Which architecture foundation should be established FIRST?

- A. Security principles and shared capability requirements aligned with the target enterprise service model and risk profile
- B. A detailed device configuration for every member organization
- C. A requirement that every portal use one supplier
- D. A permanent waiver allowing every portal to retain its current design

Question 21 (CISM6-078)

Scenario: An insurer's target architecture assumes centralized authorization and common event data. Current platforms use separate identities, and several cannot change during a two-year product migration.

Which next step would provide the MOST value?

- A. Approve the target state solely because it is more modern.
- B. Perform a current-to-target gap and dependency analysis defining transition states, risks, safeguards, and milestones.
- C. Replace the target architecture with a list of current products.
- D. Ask each project to resolve gaps independently.

Question 22 (CISM6-079)

Scenario: A legal archive must restrict access by case jurisdiction and preserve records for approved periods. Architecture diagrams do not show how those requirements drive services and controls.

Which architecture artifact should the manager request?

- A. A larger inventory of server models
- B. Traceability from business and risk requirements to architecture decisions, control responsibilities, data flows, and acceptance evidence
- C. A list of the architecture team's qualifications
- D. A statement that the design uses current industry trends

Question 23 (CISM6-080)

Scenario: A mobile-app company has security architecture principles, but teams review them only before release. Designs are already fixed when exceptions are requested.

Which governance change would BEST improve conformance?

- A. Add early risk-tiered checkpoints, approved patterns, and a documented exception and escalation process.
- B. Ban every exception regardless of business context.
- C. Have internal audit design application controls.
- D. Review only applications that have experienced incidents.

Question 24 (CISM6-081)

Scenario: A media network can consolidate identity services through a single companywide cutover or business-unit phases. The cutover is faster but risks production disruption; phasing requires temporary federation.

Which roadmap evaluation is MOST appropriate?

- A. Choose the fastest option because shorter duration always means lower risk.
- B. Compare risk reduction, operational resilience, dependencies, interim controls, support capacity, lifecycle cost, and exit criteria.
- C. Retain fragmented services indefinitely.
- D. Let each business unit define a permanent target architecture.

Question 25 (CISM6-082)

Which metric BEST measures the outcome of security exception management?

- A. Number of pages in the exception procedure
- B. Hours spent configuring the workflow system
- C. Percentage of active exceptions with accountable approval, current safeguards, timely review, and closure by expiration
- D. Number of employees who can open the request form

Question 26 (CISM6-083)

Scenario: A code-review initiative reports that every project completed required reviews. Serious security defects discovered after release have not declined.

How should the information security manager interpret the results?

- A. Stop measuring post-release defects because they conflict with completion data.
- B. Declare success because the review requirement was completed.
- C. Treat completion as activity evidence and analyze review quality, coverage, timing, defect causes, and outcome trends.
- D. Increase the number of review forms without examining practice.

Question 27 (CISM6-084)

Scenario: A manufacturing group proposes raising every program capability to the same maturity level. Some capabilities support critical production, while others serve low-impact administrative processes.

Which capability-target recommendation should the information security manager make?

- A. Set differentiated targets based on risk, business reliance, desired outcomes, dependencies, affordability, and expected value.
- B. Use the same maximum target because uniformity guarantees acceptable risk.
- C. Fund only capabilities with the lowest present scores.
- D. Stop using maturity information entirely.

Question 28 (CISM6-085)

Which factor is MOST important when judging whether a security control is suitably designed?

- A. The control's popularity among peer organizations
- B. The age of the supporting technology
- C. The number of settings available
- D. Its fit with the objective, risk, business, and architecture

Question 29 (CISM6-086)

Scenario: A university plans shared analysis spaces for researchers from multiple institutions. A proposed control blocks all external access, preventing the approved collaboration model.

Which control-selection approach should the manager use?

- A. Approve the block because maximum restriction always minimizes total risk.
- B. Select layered controls that support authorized research collaboration
- C. Allow unrestricted external access to preserve collaboration.
- D. Let each researcher disable controls independently.

Question 30 (CISM6-087)

Scenario: An insurer protects customer documents in its portal, but employees can download them to unmanaged local folders. The approved risk scenario includes misuse after download.

Which management response BEST closes the gap?

- A. Increase portal password length without addressing local copies.
- B. Accept the design because portal access is controlled.
- C. Reassess end-to-end coverage and add proportionate controls for download, local use, monitoring, retention, and disposal.
- D. Ask internal audit to operate endpoint controls.

Question 31 (CISM6-088)

Scenario: A ticket marketplace can manually approve every seller payout change or use layered automated checks with targeted human review. Both meet minimum requirements but have different error and scale characteristics.

Which analysis should guide the choice?

- A. Compare scenario coverage, false decisions, scalability, resilience, response capacity, user impact, and lifecycle cost.
- B. Choose the option with the most individual checks.
- C. Select the control preferred by the technology supplier.
- D. Choose the lowest initial cost regardless of operations.

Question 32 (CISM6-089)

Scenario: A warehouse operator deploys environmental security monitoring. Sensors send alerts, but no team owns response, thresholds are unapproved, and escalation procedures are missing.

What must occur before the control is considered implemented?

- A. The sensor supplier confirms installation.
- B. The project spends its remaining budget.
- C. Internal audit assumes alert-response ownership.
- D. Ownership, approved thresholds, integration, procedures, training, escalation, and acceptance evidence are established.

Question 33 (CISM6-090)

Scenario: A software company plans new products carefully but retires old services without security participation. Data copies, customer access, supplier accounts, and monitoring often remain afterward.

Which retirement-lifecycle change is MOST appropriate?

- A. Review retired services only after a security incident.
- B. Ask internal audit to operate every decommissioning task.
- C. Add risk-tiered security closure criteria to the project lifecycle
- D. Treat retirement as outside the security program.

Question 34 (CISM6-091)

Scenario: Engineers bypass a new privileged-access request process because approvals take days and emergency maintenance has no defined route. Managers have not assigned backup approvers.

Which adoption response should the information security manager take FIRST?

- A. Send more reminders without changing the process.
- B. Declare success because the request portal is available.
- C. Correct approval barriers and manage interim risk
- D. Remove privileged-access approval entirely.

Question 35 (CISM6-092)

Scenario: A mining company pilots a connection-control service at its corporate office. Remote sites use specialized equipment and limited bandwidth, and neither production impact nor local support has been tested.

Which rollout decision BEST reflects the evidence?

- A. Let each site decide whether the control applies.
- B. Deploy everywhere immediately because the office pilot passed.
- C. Cancel the control because the pilot did not include every site.
- D. Validate representative site workflows, equipment, bandwidth, support, acceptance criteria, and rollback before phased expansion.

Question 36 (CISM6-093)

Scenario: A company reports successful record deletion because scheduled jobs complete. It has not verified whether all repositories are included, legal holds are preserved, or deleted records remain recoverable.

What should the revised control test include?

- A. Only the successful job-completion logs
- B. The date on which the retention policy was approved
- C. The operator's opinion that deletion is reliable
- D. Repository completeness, rule accuracy, hold handling, disposal evidence, recoverability, exceptions, and remediation

Question 37 (CISM6-094)

Scenario: Critical application findings remain overdue because remediation must pass through a release process that gives security defects no priority. Teams repeatedly extend dates without addressing the shared constraint.

Which remediation action is MOST appropriate?

- A. Correct the release-process root cause and track sustainable performance
- B. Close findings when teams acknowledge them.
- C. Continue extending every due date independently.
- D. Transfer application releases to the assurance team.

Question 38 (CISM6-095)

Which statement about independent assurance is MOST accurate?

- A. Independent review with owner accountability for monitoring and remediation
- B. Independent assurance removes the need for management monitoring.
- C. Control operators should approve the review's final conclusion.
- D. Independent assurance transfers control ownership to the reviewer.

Question 39 (CISM6-096)

Scenario: A data-masking control is declared effective based on one successful test at launch. New datasets and interfaces have been added during the following year without further evaluation.

Which evidence conclusion should the information security manager reach?

- A. Launch testing proves continued effectiveness for all later data.
- B. Evaluation should wait until unmasked data is exposed.
- C. Automated controls require no testing after activation.
- D. The evidence is insufficient; assurance should cover current population, changes, operation over time, exceptions, and relevant outcomes.

Question 40 (CISM6-097)

What is the PRIMARY objective of a security awareness program?

- A. To maximize the number of messages sent by security
- B. To improve security-relevant decisions and behavior in ways that reduce applicable risk
- C. To transfer control ownership to individual users
- D. To provide identical technical training to every employee

Question 41 (CISM6-098)

Scenario: Technical support agents complete general security training but still disclose account details when callers provide incomplete verification and claim urgency.

Which training response is MOST appropriate?

- A. Repeat the same general training for the entire workforce.
- B. Measure effectiveness only through course completion.
- C. Use role-specific scenarios and workflow prompts for verification and escalation, then measure observed behavior.
- D. Make the security team handle every customer call.

Question 42 (CISM6-099)

Scenario: Engineering teams complete secure-design training, but one product group continues to bypass required threat reviews during rapid release cycles.

Which awareness-program action should occur NEXT?

- A. Declare success because all engineers completed training.
- B. Correct workflow drivers and measure review behavior
- C. Stop measuring behavior because results differ across teams.
- D. Add identical generic content for every employee.

Question 43 (CISM6-100)

Scenario: A property manager wants a provider to operate tenant access and visitor records. Procurement has reviewed price but not privileged access, incidents, subcontractors, evidence, retention, or termination.

Which provider-governance requirement is MOST appropriate?

- A. A general confidentiality clause as the only control
- B. Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, retention, continuity, and exit terms
- C. Transfer of tenant-information ownership to the provider
- D. Approval based only on the provider's market reputation

Question 44 (CISM6-101)

Scenario: A benefits provider begins using a new subcontractor to store employee documents in a region not assessed during onboarding. Contractual notice was required but not given.

Which fourth-party response should the manager take FIRST?

- A. Ignore the change because the direct provider remains responsible.
- B. Wait until contract renewal to consider the new location.
- C. Assume direct control of the subcontractor's operations.
- D. Assess the change and invoke approval or corrective rights

Question 45 (CISM6-102)

Scenario: A membership organization is replacing its payment-support provider. The proposed exit transfers current cases but excludes historical evidence, active provider accounts, and backup deletion.

Which exit plan is BEST?

- A. Terminate immediately and reconstruct missing history later.
- B. Keep both providers indefinitely to avoid transition decisions.
- C. Test a coordinated transfer of required cases and evidence, preserve continuity, revoke access, verify deletion, and obtain accountable acceptance.
- D. Rely on the former provider's verbal assurance that copies are safe.

Question 46 (CISM6-103)

Scenario: A board committee receives a quarterly list of alerts, completed tasks, and technology deployments. Members cannot see which business risks changed or where intervention is required.

Which reporting design would BEST support the committee?

- A. A larger appendix containing every alert
- B. A list of activities performed only by the security team
- C. A report limited to positive results
- D. Trends against program outcomes and risk thresholds, business implications, accountable owners, and required decisions

Question 47 (CISM6-104)

Scenario: A data-protection initiative is blocked because business units have not assigned information owners. The delay now exceeds an approved threshold, and the security manager cannot assign ownership for them.

Which escalation action should the manager take NEXT?

- A. Omit the dependency until business units respond.
- B. Assign security staff as permanent owners of all business data.
- C. Move the milestone so the dashboard appears acceptable.
- D. Escalate through the defined governance route with impact, evidence, missing accountability, options, and the decision required.

Question 48 (CISM6-105)

Scenario: A security team designs a centralized certificate service without consulting application owners. Adoption stalls because service levels do not match release schedules and ownership of renewals is unclear.

Which engagement approach would BEST improve adoption?

- A. Jointly define outcomes, service levels, dependencies, renewal responsibilities, exceptions, and success measures with affected owners.
- B. Require teams to use the existing design without review.
- C. Transfer all certificate accountability to application developers individually.
- D. Cancel the security objective to avoid disagreement.

Question 49 (CISM6-106)

Scenario: After a merger, two sales organizations combine customer processes but retain different access approvals, training, metrics, and supplier arrangements.

Which merger-related maintenance action should occur FIRST?

- A. Apply the larger company's controls unchanged without assessment.
- B. Keep both programs permanently separate.
- C. Wait for incidents to reveal integration needs.
- D. Assess combined workflows, information, ownership, obligations, risks, and dependencies, then update controls and the roadmap.

Question 50 (CISM6-107)

Scenario: An engineering firm wants spatial-computing headsets to display sensitive facility models. Recording, identity, cloud processing, supplier access, and existing control coverage are not understood.

Which emerging-technology program response is MOST appropriate?

- A. Set provider guardrails, run a pilot, monitor outcomes, and update controls
- B. Permit unrestricted use until a confirmed event occurs.
- C. Ban the technology permanently because current policies do not name it.
- D. Let each engineering team create unrelated requirements.

Answer Key

Domain III - Information Security Program

1 C	2 D	3 A	4 B	5 A
6 C	7 A	8 B	9 A	10 C
11 D	12 B	13 C	14 B	15 B
16 D	17 C	18 A	19 B	20 A
21 B	22 B	23 A	24 B	25 C
26 C	27 A	28 D	29 B	30 C
31 A	32 D	33 C	34 C	35 D
36 D	37 A	38 A	39 D	40 B
41 C	42 B	43 B	44 D	45 C
46 D	47 D	48 A	49 D	50 A

Detailed Explanations

Question 1 (CISM6-058)

Correct answer: C - The digital services, user information, public obligations, dependencies, and associated risks

Objectives should derive from the library's new services, information, obligations, dependencies, and risk exposure. Tool age and peer practices are only inputs, while avoiding process change may leave important service risks untreated.

Question 2 (CISM6-059)

Correct answer: D - An approved charter defining enterprise authority, brand responsibilities, scope, objectives, sponsorship, and escalation

A sponsored charter provides the mandate and shared accountability required across the group. Technical catalogs and audits cannot create decision authority, while unrelated policies would deepen fragmentation.

Question 3 (CISM6-060)

Correct answer: A - Reassess the partnership risks and dependencies, then propose a funded sequence aligned with the launch date.

The partnership changes both exposure and capability timing, requiring a transparent, risk-based roadmap adjustment. Freezing the plan, adding unsupported work, or delaying safeguards would not align the program with the business change.

Question 4 (CISM6-061)

Correct answer: B - Map end-to-end services, information flows, obligations, risks, dependencies, and accountable interfaces across participants.

Program scope should follow the business service and information risk across organizational boundaries, with clear interface responsibilities. Technology ownership and employment status do not remove exposure, and providers cannot accept all platform accountability.

Question 5 (CISM6-062)

Correct answer: A - Forecast review demand, risk tiers, service levels, required competencies, workflow complexity, and automation

Staffing should reflect forecast demand, risk, service expectations, skills, process complexity, and automation. Other department size, product count, and one peer benchmark do not establish the capacity required by this organization.

Question 6 (CISM6-063)

Correct answer: C - Use qualified advisors under internal governance, with defined deliverables, knowledge transfer, and retained decision ownership.

External advisors can close a temporary expertise gap while internal governance, ownership, and knowledge transfer preserve alignment and continuity. Risk decisions cannot be outsourced, permanent vendor ownership is inappropriate, and indefinite delay is unnecessary.

Question 7 (CISM6-064)

Correct answer: A - A business case covering risk reduction, benefits, dependencies, effort, and cost

The business case must account for expected value and the data, process, integration, and change prerequisites needed to realize it. Feature counts and visibility are incomplete, while no workflow tool can eliminate all supplier risk.

Question 8 (CISM6-065)

Correct answer: B - Create a competency and succession plan covering knowledge transfer, development, recruitment, and interim support.

A competency-based succession plan addresses continuity, capacity, and knowledge before the departure occurs. Withholding documentation and waiting increase dependency, while internal audit should not operate management capabilities.

Question 9 (CISM6-066)

Correct answer: A - The accountable information owner

The information owner has business accountability to approve classification and handling needs. Providers and operators act as custodians, while auditors assess rather than own classification decisions.

Question 10 (CISM6-067)

Correct answer: C - Embedding ownership review and reassignment into organizational change and asset lifecycle processes

Integrating ownership review with business change enables timely reassignment and continued accountability. Security does not own all assets, audit-only review is delayed, and former employees cannot remain valid owners.

Question 11 (CISM6-068)

Correct answer: D - Define classification-based media controls and embed them in production and partner workflows.

Classification must drive practical handling rules across the media lifecycle and relevant workflows. Removing labels hides sensitivity, central approval will not scale, and purchase counts do not demonstrate protection.

Question 12 (CISM6-069)

Correct answer: B - Assign accountable owners and determine business, contractual, and legal requirements before controlled transfer, retention, and disposal.

Ownership and applicable requirements must be established before defensible separation decisions are made. Indiscriminate copying or deletion can violate obligations, and administrators lack the business authority to determine ownership alone.

Question 13 (CISM6-070)

Correct answer: C - Its fit with organizational objectives, risks, obligations, capabilities, and governance

Framework selection should be based on organizational fit and support for relevant outcomes. Control quantity and publisher visibility are secondary, and no framework removes the need for management judgment and tailoring.

Question 14 (CISM6-071)

Correct answer: B - To focus effort on relevant outcomes while preserving traceability to risks and applicable requirements

Tailoring aligns effort with relevant risk, business needs, and obligations while preserving traceability. It is not a convenience-based omission process, cannot eliminate all residual risk, and does not replace governance.

Question 15 (CISM6-072)

Correct answer: B - Map regional requirements to a common control and evidence model while preserving unique obligations and traceability.

A common control model reduces duplication while preserving evidence and accountability for distinct regional needs. Using the weakest library creates gaps, separation wastes effort, and assumed equivalence can miss material differences.

Question 16 (CISM6-073)

Correct answer: D - Policy

Policy expresses management's authoritative direction and intent. Procedures describe execution, guidelines offer recommendations, and test records provide assurance evidence.

Question 17 (CISM6-074)

Correct answer: C - When recommended approaches can help users meet requirements in varying circumstances

Guidelines offer adaptable recommendations for meeting governing requirements. Charters establish authority, standards contain mandatory technical minima, and risk acceptance requires an accountable decision rather than advisory guidance.

Question 18 (CISM6-075)

Correct answer: A - Documented risk, accountable approval, compensating controls, monitoring, review triggers, and a defined expiration date

A valid exception must be risk-based, approved by the proper authority, supported by interim safeguards, monitored, and time-limited. Permanent exclusion and technician approval bypass governance, while incident history does not establish acceptable future exposure.

Question 19 (CISM6-076)

Correct answer: B - Update, approve, and communicate the affected procedures while retaining traceability to the valid policy and standard.

The obsolete operating instructions should be formally updated while remaining aligned with valid governing requirements. Unnecessary policy revision wastes effort, informal local processes create inconsistency, and stale procedures remain a source of control failure.

Question 20 (CISM6-077)

Correct answer: A - Security principles and shared capability requirements aligned with the target enterprise service model and risk profile

Aligned principles and shared capabilities guide consistent solutions within the target enterprise architecture. Supplier uniformity and device detail do not ensure alignment, while permanent waivers preserve the fragmentation.

Question 21 (CISM6-078)

Correct answer: B - Perform a current-to-target gap and dependency analysis defining transition states, risks, safeguards, and milestones.

A gap and dependency analysis turns the target into an achievable, risk-managed transition plan. Modernity alone is not validation, independent project decisions create inconsistency, and a product list is not a target architecture.

Question 22 (CISM6-079)

Correct answer: B - Traceability from business and risk requirements to architecture decisions, control responsibilities, data flows, and acceptance evidence

Traceability demonstrates how the design implements jurisdiction and retention requirements and provides a basis for acceptance. Hardware details, trends, and staff qualifications do not show that the requirements are satisfied.

Question 23 (CISM6-080)

Correct answer: A - Add early risk-tiered checkpoints, approved patterns, and a documented exception and escalation process.

Early, proportionate checkpoints and reusable patterns let teams address architecture before design commitment while preserving accountable exceptions. Absolute bans are inflexible, audit should not design controls, and incident-based review is reactive.

Question 24 (CISM6-081)

Correct answer: B - Compare risk reduction, operational resilience, dependencies, interim controls, support capacity, lifecycle cost, and exit criteria.

The roadmap should balance target-state benefits with transition risk, resilience, dependencies, support, and cost. Speed alone is insufficient, indefinite delay preserves weaknesses, and separate targets continue fragmentation.

Question 25 (CISM6-082)

Correct answer: C - Percentage of active exceptions with accountable approval, current safeguards, timely review, and closure by expiration

Approval, current safeguards, timely review, and closure show whether exceptions are governed as intended. Procedure length, implementation effort, and form access are activity or design measures rather than outcomes.

Question 26 (CISM6-083)

Correct answer: C - Treat completion as activity evidence and analyze review quality, coverage, timing, defect causes, and outcome trends.

Completion shows that an activity occurred, not whether it was timely, complete, or effective. Quality and outcome analysis can reveal the gap, while ignoring defects or adding forms does not establish risk reduction.

Question 27 (CISM6-084)

Correct answer: A - Set differentiated targets based on risk, business reliance, desired outcomes, dependencies, affordability, and expected value.

Target maturity should be appropriate to each capability's risk and business value rather than uniformly maximal. Low scores alone do not establish priority, while contextual maturity assessment remains useful for investment decisions.

Question 28 (CISM6-085)

Correct answer: D - Its fit with the objective, risk, business, and architecture

A suitable design is traceable to the intended objective and risk and fits relevant requirements and operating conditions. Popularity, technology age, and setting counts do not demonstrate effectiveness or proportionality.

Question 29 (CISM6-086)

Correct answer: B - Select layered controls that support authorized research collaboration

Control selection should support authorized collaboration while reducing information risk through proportionate layered safeguards. Total blocking defeats the business objective, unrestricted access abandons protection, and individual disabling lacks governance.

Question 30 (CISM6-087)

Correct answer: C - Reassess end-to-end coverage and add proportionate controls for download, local use, monitoring, retention, and disposal.

The control set must cover the full information path, including use after download. Portal controls and password changes do not protect local copies, while internal audit should assess controls rather than operate them.

Question 31 (CISM6-088)

Correct answer: A - Compare scenario coverage, false decisions, scalability, resilience, response capacity, user impact, and lifecycle cost.

A sound decision balances risk coverage with error consequences, scale, resilience, response capacity, business impact, and total cost. Check count, supplier preference, and initial price alone do not establish the better strategy.

Question 32 (CISM6-089)

Correct answer: D - Ownership, approved thresholds, integration, procedures, training, escalation, and acceptance evidence are established.

Implementation requires a complete operating model and validated readiness, not merely installed sensors. Budget use does not prove effectiveness, and internal audit should independently assess rather than operate the response process.

Question 33 (CISM6-090)

Correct answer: C - Add risk-tiered security closure criteria to the project lifecycle

Security closure criteria ensure decommissioning addresses residual information, access, suppliers, and evidence as part of normal delivery. Incident-based review is reactive, audit should not operate closure, and retirement remains part of the control lifecycle.

Question 34 (CISM6-091)

Correct answer: C - Correct approval barriers and manage interim risk

The program must fix the ownership and workflow barriers that make compliant behavior impractical while governing interim exposure. Portal availability and reminders do not resolve them, while removing approval abandons the control objective.

Question 35 (CISM6-092)

Correct answer: D - Validate representative site workflows, equipment, bandwidth, support, acceptance criteria, and rollback before phased expansion.

A controlled rollout should extend testing to the distinct operational environment and confirm support and recovery readiness. Office results cannot simply be generalized, cancellation wastes a viable control, and local choice undermines consistent governance.

Question 36 (CISM6-093)

Correct answer: D - Repository completeness, rule accuracy, hold handling, disposal evidence, recoverability, exceptions, and remediation

The test must cover the full retention objective, including population completeness, valid holds, effective disposal, and exceptions. Job logs, policy dates, and operator opinion do not establish that all required records are handled correctly.

Question 37 (CISM6-094)

Correct answer: A - Correct the release-process root cause and track sustainable performance

The recurring delays arise from a shared process constraint, so sustainable remediation must correct that cause and prioritize exposure. Extensions and acknowledgement do not reduce risk, while assurance should not operate releases.

Question 38 (CISM6-095)

Correct answer: A - Independent review with owner accountability for monitoring and remediation

Independent assurance provides objective evaluation without transferring ownership or replacing management oversight. Operators should support evidence collection but should not control the independent conclusion.

Question 39 (CISM6-096)

Correct answer: D - The evidence is insufficient; assurance should cover current population, changes, operation over time, exceptions, and relevant outcomes.

A launch test does not demonstrate that later datasets, interfaces, and changes remain covered or that operation is sustained. Automation does not eliminate assurance, and waiting for exposure is reactive.

Question 40 (CISM6-097)

Correct answer: B - To improve security-relevant decisions and behavior in ways that reduce applicable risk

Awareness should change relevant behavior and decisions to reduce human and process risk. Message volume and uniform content are activities, while awareness does not transfer control accountability to users.

Question 41 (CISM6-098)

Correct answer: C - Use role-specific scenarios and workflow prompts for verification and escalation, then measure observed behavior.

Role-specific scenarios and decision-time prompts address the actual pressure point and enable behavioral measurement. Generic repetition and completion are indirect, while shifting support work to security is not scalable or properly owned.

Question 42 (CISM6-099)

Correct answer: B - Correct workflow drivers and measure review behavior

The segmented result identifies a specific behavioral and workflow gap that needs targeted analysis, reinforcement, and follow-up measurement. Completion alone is not effectiveness, while stopping measurement or adding generic content will not address the cause.

Question 43 (CISM6-100)

Correct answer: B - Risk-based due diligence and defined access, evidence, incident, subcontractor, monitoring, retention, continuity, and exit terms

The service requires lifecycle governance proportionate to tenant and physical-access risk. A single clause and reputation are insufficient, while the organization retains information ownership and accountability.

Question 44 (CISM6-101)

Correct answer: D - Assess the change and invoke approval or corrective rights

The unapproved location and subcontractor change requires timely assessment and use of contractual governance. Direct-provider accountability does not remove the exposure, waiting prolongs it, and the customer should not operate the subcontractor.

Question 45 (CISM6-102)

Correct answer: C - Test a coordinated transfer of required cases and evidence, preserve continuity, revoke access, verify deletion, and obtain accountable acceptance.

A complete exit preserves required information and continuity while ending access and verifying deletion. Immediate termination can strand evidence, indefinite duplication increases exposure, and verbal assurance is not sufficient proof.

Question 46 (CISM6-103)

Correct answer: D - Trends against program outcomes and risk thresholds, business implications, accountable owners, and required decisions

Board reporting should connect program performance to business risk, outcomes, ownership, and decisions. Raw alerts obscure significance, positive-only reporting undermines oversight, and security-only activity can omit enterprise dependencies.

Question 47 (CISM6-104)

Correct answer: D - Escalate through the defined governance route with impact, evidence, missing accountability, options, and the decision required.

The exceeded threshold and missing authority require transparent escalation to the appropriate decision body. Security should not assume business ownership, while changing dates or omitting the issue conceals exposure.

Question 48 (CISM6-105)

Correct answer: A - Jointly define outcomes, service levels, dependencies, renewal responsibilities, exceptions, and success measures with affected owners.

Joint design aligns the service with delivery needs and clarifies shared responsibilities and measures. Unilateral enforcement weakens adoption, fragmented individual accountability may create inconsistency, and cancellation abandons the objective.

Question 49 (CISM6-106)

Correct answer: D - Assess combined workflows, information, ownership, obligations, risks, and dependencies, then update controls and the roadmap.

The merged operating model requires a structured assessment before harmonizing controls, responsibilities, measures, and priorities. Size alone does not prove suitability, permanent separation preserves inconsistency, and incident-driven change is reactive.

Question 50 (CISM6-107)

Correct answer: A - Set provider guardrails, run a pilot, monitor outcomes, and update controls

Governed experimentation enables business learning while addressing data, recording, architecture, and supplier risks and feeding evidence into program improvement. Unrestricted use lacks safeguards, a permanent ban avoids proportionate assessment, and team-specific rules fragment governance.